TECHNICAL EVALUATION METHODOLOGY & DELIVERABLE SPECIFICATION

Sentinel 25-Control Passive Assessment Framework

Author: Kaled Bouchagraoui
Repository: github.com/kaledbouchagraoui7-bot/medtech-regulatory-compliance-suite

This 1-page sheet outlines the 25 passive external checks used to review public business domains. Every check relies solely on standard DNS-over-HTTPS queries, public TLS certificate metadata, and a single HTTPS GET request identical to an ordinary web browser visit, without port scanning or intrusive probing.

01 · Passive Collectors

Queries Cloudflare and Google DNS-over-HTTPS (TXT, MX, CAA), inspects TLS 1.2/1.3 certificate validity, and reads one standard public HTTPS response.

02 · 25-Control Matrix

Evaluates 25 deterministic rules across email authentication, pre-consent privacy leaks, browser security headers, WCAG 2.1 AA, and structured Schema.org.

03 · Clinical & RA Add-Ons

Optional modules automate PRISMA 2020 clinical literature tables (EU MDR Annex XIV), OpenFDA MAUDE safety digests (PSUR), and eCTD cross-checks.

04 · Turnkey Config Fixes

Outputs copy-paste DNS records, Nginx and Cloudflare header snippets, Word and Excel audit tables, plus a verification re-scan after deployment.

EVALUATION CONTROL MATRIX & REGULATORY MAPPING

Pillar 1 · Email Authentication & Anti-Spoofing (4 Controls)	EML-01 DMARC enforcement policy (p=quarantine / p=reject vs missing or p=none) · EML-02 SPF syntax & 10-lookup ceiling · EML-03 MX mail routing · EML-04 DNS CAA certificate lock (RFC 7489, RFC 7208, RFC 8659).
Pillar 2 · Web Privacy & Cross-Border Data Hygiene (4 Controls)	PRV-01 Pre-consent remote Google Fonts IP transfer check · PRV-02 Initial HTML third-party ad/analytics tracker scan · PRV-03 Cookie Secure, HttpOnly & SameSite flags · PRV-04 Discoverable Privacy Policy link (GDPR Art. 13/44, Swiss nFADP).
Pillar 3 · Edge Transport & Browser Security Headers (9 Controls)	SEC-01 TLS 1.2/1.3 & certificate expiry · SEC-02 HSTS · SEC-03 Content-Security-Policy · SEC-04 X-Frame-Options · SEC-05 X-Content-Type-Options: nosniff · SEC-06 Referrer-Policy · SEC-07 Permissions-Policy · SEC-08 Server fingerprinting · SEC-09 security.txt.
Pillar 4 · Accessibility (WCAG 2.1 AA / EAA) & Pillar 5 · Technical SEO (8 Controls)	A11Y-01 Root html lang attribute · A11Y-02 Image alt coverage · A11Y-03 Viewport pinch-to-zoom freedom · A11Y-04 Single h1 heading · SEO-01 Title & meta description · SEO-02 Canonical URL · SEO-03 JSON-LD Schema.org · SEO-04 robots.txt.

Standard Remediation & Verification Scope: When engaged for a fixed-fee remediation package, deliverables include the full Word and 4-sheet Excel audit dossier, copy-paste DNS records (DMARC, SPF, CAA), ready-to-deploy Nginx, Apache, or Cloudflare security headers, local webfont privacy guidance, and a post-deployment verification re-scan once your team applies the changes.